

TAREA IC02

Clasificación de riesgos y potenciales incidentes.

Autor: Carlos España Del Pozo - CETI

Contenido

Clasificación de riesgos y potenciales incidentes.	3
Apartado 1: Priorización y jerarquía de activos.....	4
Respuestas 1	4
Apartado 2: Valoración de los dominios de seguridad.	7
Respuestas 2	7
Apartado 3: Determinación de las amenazas y sus salvaguardas dispuestas.	9
Respuestas 3	9
Apartado 4: Estimación del riesgo que tendría que considerar la empresa para su estudio y toma de decisiones.	10
Respuestas 4	11
Apartado 5: Taxonomía de incidentes.	11
Respuestas 5	12

Clasificación de riesgos y potenciales incidentes.

Un Sistema de Gestión de Seguridad de la Información debe disponer de un correcto sistema de gestión de riesgos.

Un proceso de gestión de riesgos de seguridad de la información trata de identificar, comprender, evaluar y mitigar los riesgos.

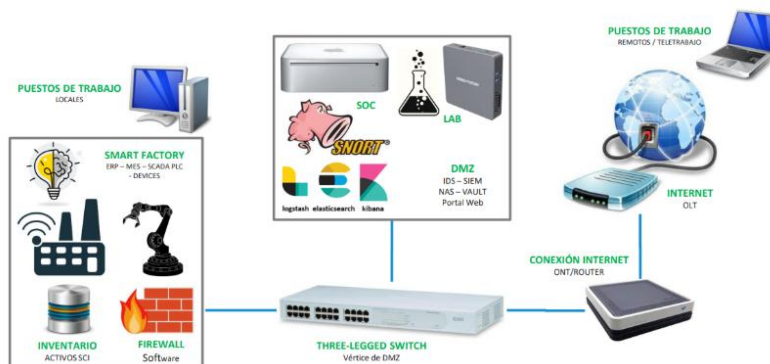
El concepto de riesgo se corresponde con la probabilidad de que se produzca un incidente de seguridad, materializándose una amenaza y causando pérdidas o daños. El riesgo depende entonces de los siguientes factores: la probabilidad de que la amenaza se materialice aprovechando una vulnerabilidad y produciendo un daño o impacto. El producto de estos factores representa el riesgo.

En esta tarea realizaremos un análisis y gestión de riesgos en la empresa ficticia de la unidad anterior para evitar o disminuir la probabilidad de que se produzcan diversos incidentes. Para este análisis seguiremos la metodología MAGERIT v.3 desarrollada por el gobierno español.

Además, haremos uso de la herramienta PILAR (versión Basic) que implementa la metodología MAGERIT que ha sido desarrollada por el Centro Criptológico Nacional (CCN). Este software es privativo y debe licenciarse, pero provee de una licencia de evaluación de 30 días, que es la que usaremos en este caso práctico.

Introducción: Diagrama de bloques y detalles de activos de la empresa.

La empresa tiene el siguiente diagrama de bloques:



La empresa tiene los siguientes activos materiales principales:

Activo	Dirección IP	Sistema Operativo	Modelo Máquina	Función Empresa
Router	192.168.1.1	Askey SO	RTF3505VW	Router conexión Internet
Switch	192.168.1.11	3COM SO	SuperStack 3 3300XM	Three-Legged Switch
SOC	192.168.1.101	MacOS Ventura	Mac Mini M1	IDS/SIEM/NAS/VAULT
Labo_Server	192.168.1.102	Debian 11	MinisForum HM90	Servidor Laboratorio
ERP	192.168.1.25	Debian 11	ProLiant uServer Intel Xeon E	Servidor Gestor Empresarial
MES	192.168.1.24	Raspbian	Raspberry Pi 4B	Servidor Gestor Factoria
SCADA	192.168.1.23	Raspbian	Raspberry Pi 4B	Supervisión / Control / Firewall / Inventario
PLC	192.168.1.22	Raspbian	Raspberry Pi 4B	Controlador lógico
DEVICE	192.168.1.21	Raspbian	Raspberry Pi 4B	Dispositivo fabril
B.D. Inventario	192.168.1.25	MacOS Ventura	Mac Mini M1	Base de datos de Inventario
B.D. ECO/FIN	192.168.1.25	MacOS Ventura	Mac Mini M1	Base de datos ECO / FIN
Puestos trabajo	192.168.1.50-99	Windows 11 Pro	Lenovo ThinkCentre M720t	Puestos de trabajo
Maquetas, Prototipos	192.168.1.102	Debian 11	MinisForum HM90	Maquetas, prototipos, lanzaderas
Portal Web	192.168.1.102	Debian 11	MinisForum HM90	Portales web
Big Data, IA	192.168.1.50-99	Windows 11	Lenovo ThinkCentre M720t	Sistemas Big Data, IA

Nota: Todos los datos no proporcionados de la empresa deben ser definidos de forma autónoma y libre como si fueras parte de la dirección general de la empresa, justificando su elección. Por ejemplo: se puede decidir si los equipos actualmente disponen de una política de contraseñas seguras o si por el contrario no existen políticas al respecto. En cualquiera de los casos, debe exponerse en el documento de prácticas.

Apartado 1: Priorización y jerarquía de activos.

Deberás efectuar la siguiente tarea:

- A partir de la lista de activos de la introducción, se deben priorizar y jerarquizar indicando los que crees que son esenciales para la empresa. Se ordenan desde el de más importancia al de menor, además se deben indicar aquellos que dependen de otros.
- De la anterior lista de activos, se debe seleccionar uno por cada uno de estos tipos indicados: activo esencial de información, activo esencial de servicio, activo de equipamiento informático y un activo de redes de comunicación.
- Con el uso de la herramienta PILAR se debe recoger la información de los cuatro activos anteriores.
- Estos activos deben definirse en su capa correcta y en un dominio de seguridad adecuado, por lo que habrá que crear los dominios de seguridad necesarios.

Muestra la ventana detallada de información de estos cuatro activos.

Respuestas 1

Una vez revisada la información facilitada procedemos a detallar la información organizada de forma jerárquica y priorizada por importancia.

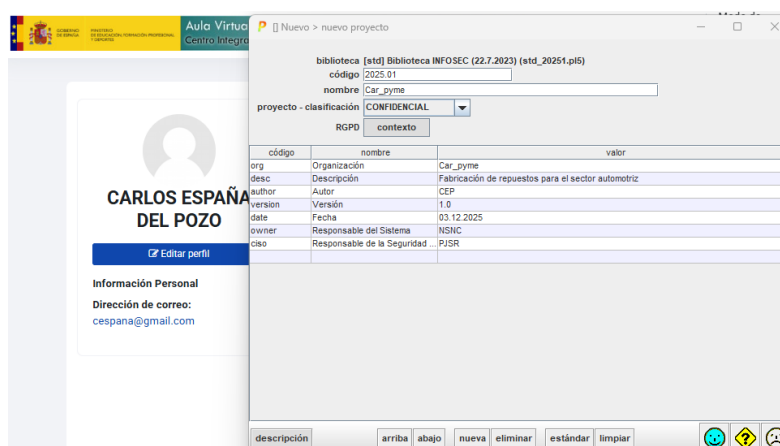
Prioridad	Activo	Dirección IP	Sistema Operativo	Modelo Máquina	Función Empresa	Dependencia
1	Switch	192.168.1.11	3COM SO	SuperStack 3 3300XM	Three-Legged Switch	Router, todos los sistemas conectados.
2	Router	192.168.1.1	Askey SO	RTF3505VW	Router conexión Internet	Sin router no tenemos acceso externo para ningún sistema.
3	ERP	192.168.1.25	Debian 11	ProLiant uServer Intel Xeon E	Servidor Gestor Empresarial	Switch, Router.
4	B.D. ECO/FIN	192.168.1.25	MacOS Ventura	Mac Mini M1	Base de datos ECO / FIN	Switch, Router.
5	B.D. Inventario	192.168.1.25	MacOS Ventura	Mac Mini M1	Base de datos de Inventario	Switch, ERP.
6	SCADA	192.168.1.23	Raspbian	Raspberry Pi 4B	Supervisión / Control / Firewall / Inventario	Switch, PLC, MES.
7	PLC	192.168.1.22	Raspbian	Raspberry Pi 4B	Controlador lógico	MES, SCADA.

8	MES	192.168.1.24	Raspbian	Raspberry Pi 4B	Servidor Gestor Factoría	Switch, SCADA.
9	SOC	192.168.1.101	MacOS Ventura	Mac Mini M1	IDS/SIEM/NAS/VAULT	Switch, Router, B.D. Inventario.
10	Portal Web	192.168.1.102	Debian 11	MinisForum HM90	Portales web	Switch, Router.
11	Labo_Server	192.168.1.102	Debian 11	MinisForum HM90	Servidor Laboratorio	Switch, Router.
12	Maquetas, Prototipos, lanzaderas	192.168.1.102	Debian 11	MinisForum HM90	Maquetas, prototipos, lanzaderas	Switch.
13	DEVICE	192.168.1.21	Raspbian	Raspberry Pi 4B	Dispositivo fabril	Switch, PLC.
14	Big Data, IA	192.168.1.50-99	Windows 11	Lenovo ThinkCentre M720t	Sistemas Big Data, IA	Switch, Router.
15	Puestos trabajo	192.168.1.50-99	Windows 11 Pro	Lenovo ThinkCentre M720t	Puestos de trabajo	Switch, Router.

Los activos esenciales en función de los tipos serían los siguientes:

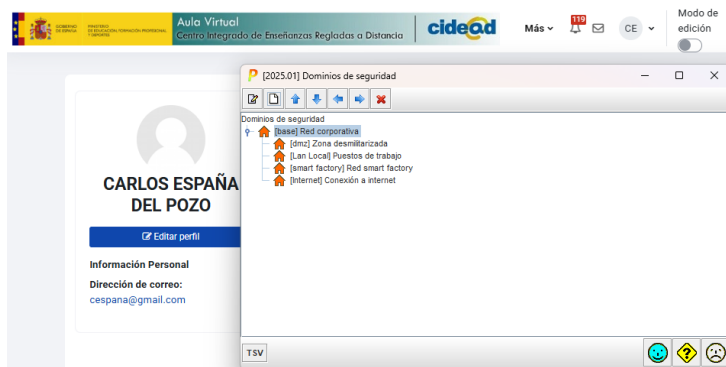
Prioridad	Activo	Función Empresa	Activo esencial	Dependencia	Motivo
1	Switch	Three-Legged Switch	Activo de Redes de Comunicación	Router, todos los sistemas conectados.	Activo core de comunicaciones internas.
3	ERP	Servidor Gestor Empresarial	Activo Esencial de Servicio	Switch, Router.	Servicio empresarial más crítico.
4	B.D. ECO/FIN	Base de datos ECO / FIN	Activo Esencial de Información	Switch, Router.	Contiene datos críticos financieros.
9	SOC	IDS/SIEM/NAS/VAULT	activo de equipamiento informático	Switch, Router, B.D. Inventario.	servicio principal para prevenir incidentes de ciberseguridad

Datos añadidos en la herramienta PILAR

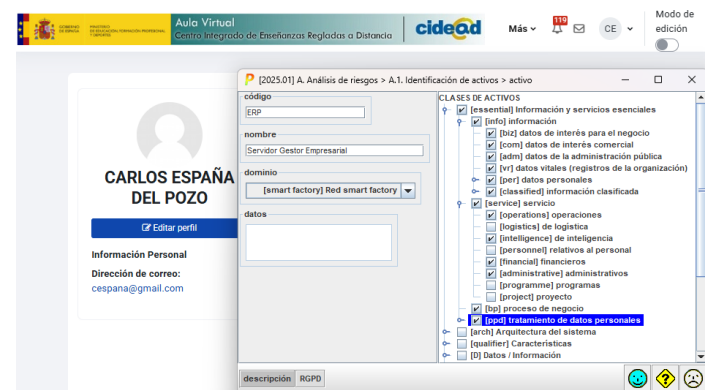
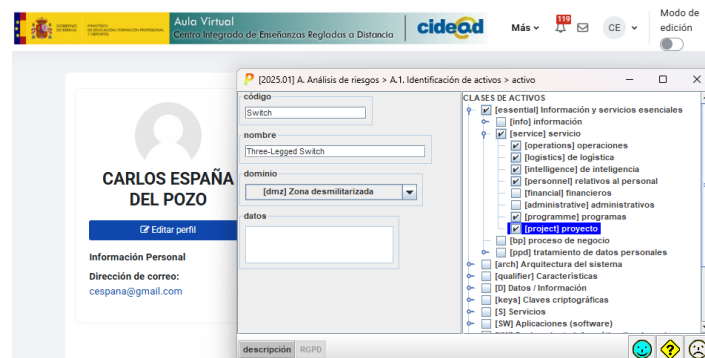
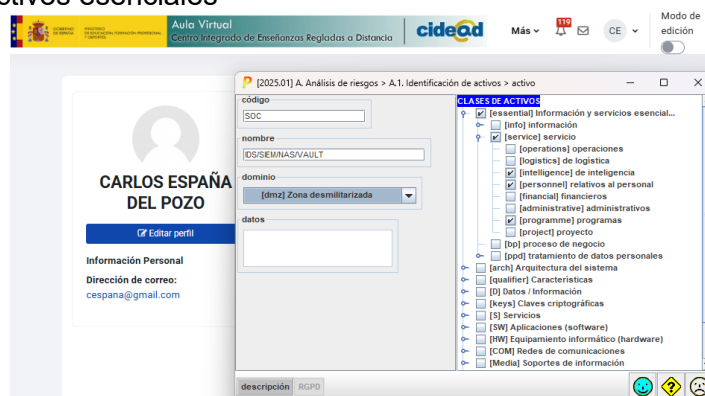


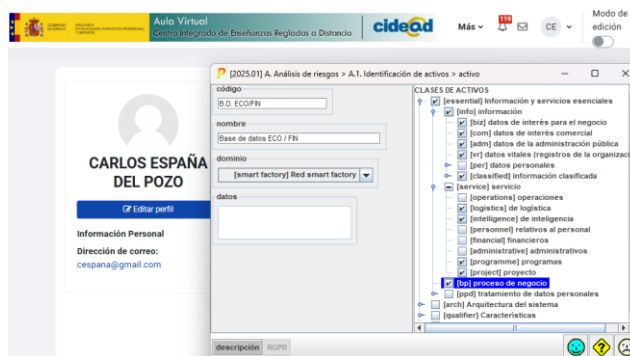
The screenshot shows the PILAR tool interface. On the left, there is a user profile for CARLOS ESPAÑA DEL POZO with an email address cespana@gmail.com. On the right, a 'Nuevo > nuevo proyecto' window is open, showing configuration details for a project named 'Biblioteca INFOSEC (22.7.2023) (std_20251.pl5)'. The project is classified as 'CONFIDENCIAL' and is associated with the 'RGPD' context. A table lists various metadata fields such as 'org', 'desc', 'author', 'version', 'date', 'owner', and 'cno' with their respective values. At the bottom of the project window, there are buttons for 'descripción', 'arriba', 'abajo', 'nueva', 'eliminar', 'estándar', and 'limpiar'.

Los diferentes dominios para el proyecto



Clasificación de los activos esenciales





Apartado 2: Valoración de los dominios de seguridad.

Deberás efectuar la siguiente tarea:

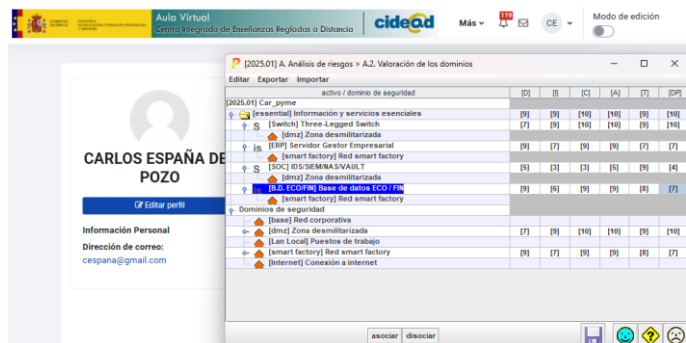
Debes determinar el nivel de importancia que tienen los activos esenciales en sus diferentes dominios de seguridad definidos.

Muestra una captura de pantalla con la valoración numérica de los activos en sus dominios de seguridad.

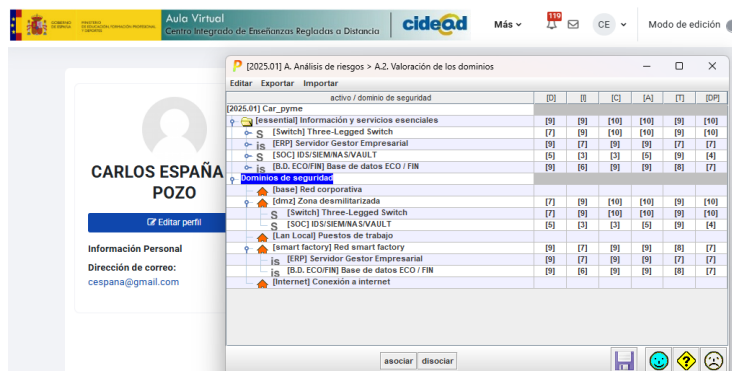
Además, debes indicar, al menos, un par de factores atenuantes y/o agravantes por cada dominio de seguridad. Muestra una captura de estos factores.

Respuestas 2

Para los activos de información, valoramos el nivel requerido de seguridad:

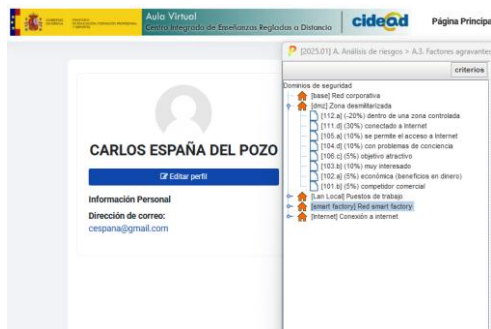


Y la valoración para cada dominio de seguridad, quedaría así:



Factores atenuantes y/o agravantes por cada dominio de seguridad

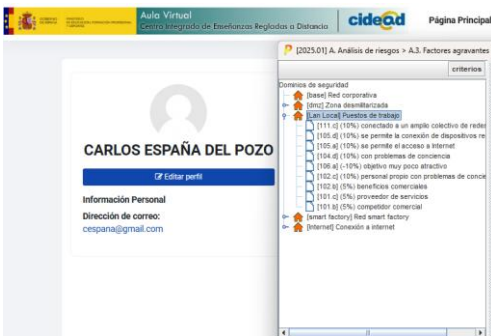
Dominio - DMZ



The screenshot shows the 'Aula Virtual' interface with the user profile of CARLOS ESPAÑA DEL POZO. On the right, the 'Factores agravantes' (Aggravating Factors) list is displayed for the 'DMZ' domain. The list includes:

- [Base] Red corporativa
- [dmz] Zona desmilitarizada
- [112 a] (-20%) dentro de una zona controlada
- [111 d] (20%) conectado a Internet
- [105 a] (10%) se permite el acceso a Internet
- [104 d] (10%) con problemas de conciencia
- [106 c] (5%) objetivo atractivo
- [103 b] (10%) muy interesado
- [102 a] (5%) económica (beneficios en dinero)
- [101 b] (5%) computador comercial
- [Smart Factory] Red smart factory
- [Internet] Conexión a Internet

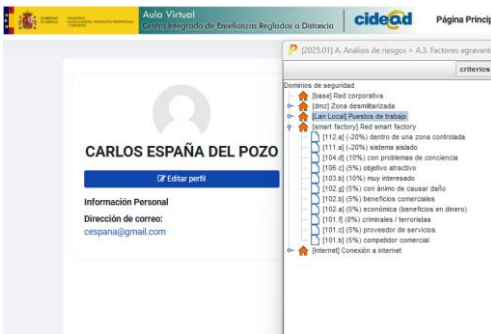
Dominio – Lan Local



The screenshot shows the 'Aula Virtual' interface with the user profile of CARLOS ESPAÑA DEL POZO. On the right, the 'Factores agravantes' list is displayed for the 'Lan Local' domain. The list includes:

- [Base] Red corporativa
- [dmz] Zona desmilitarizada
- [Lan Local] Puntos de trabajo
- [111 d] (10%) conectado a un ancho colectivo de red
- [105 d] (10%) se permite la conexión de dispositivos de red
- [105 a] (10%) se permite el acceso a Internet
- [104 d] (10%) con problemas de conciencia
- [106 a] (-10%) objetivo muy poco atractivo
- [102 c] (10%) personal propio con problemas de conciencia
- [102 b] (5%) beneficios comerciales
- [101 c] (5%) proveedor de servicios
- [Smart Factory] Red smart factory
- [Internet] Conexión a Internet

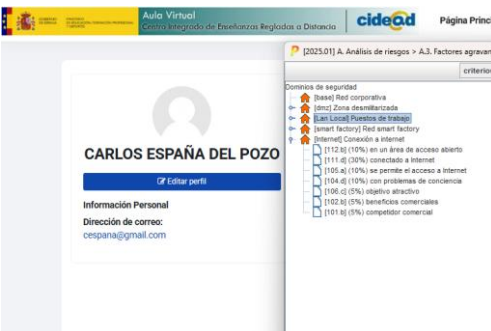
Dominio – Smart Factory



The screenshot shows the 'Aula Virtual' interface with the user profile of CARLOS ESPAÑA DEL POZO. On the right, the 'Factores agravantes' list is displayed for the 'Smart Factory' domain. The list includes:

- [Base] Red corporativa
- [dmz] Zona desmilitarizada
- [Lan Local] Puntos de trabajo
- [Smart Factory] Red smart factory
- [112 a] (-20%) dentro de una zona controlada
- [111 d] (-20%) sistema aislado
- [104 d] (10%) con problemas de conciencia
- [106 c] (5%) objetivo atractivo
- [102 b] (10%) muy interesado
- [102 a] (5%) con ánimo de causar daño
- [102 b] (5%) beneficios comerciales
- [102 a] (5%) económica (beneficios en dinero)
- [101 b] (5%) criminales / terroristas
- [101 c] (5%) proveedor de servicios
- [101 b] (5%) computador comercial
- [Internet] Conexión a Internet

Dominio – Internet



The screenshot shows the 'Aula Virtual' interface with the user profile of CARLOS ESPAÑA DEL POZO. On the right, the 'Factores agravantes' list is displayed for the 'Internet' domain. The list includes:

- [Base] Red corporativa
- [dmz] Zona desmilitarizada
- [Lan Local] Puntos de trabajo
- [Smart Factory] Red smart factory
- [Internet] Conexión a Internet
- [112 b] (10%) en un área de acceso abierto
- [111 d] (20%) conectado a Internet
- [105 a] (10%) se permite el acceso a Internet
- [104 d] (10%) con problemas de conciencia
- [106 c] (5%) objetivo atractivo
- [102 b] (5%) beneficios comerciales
- [101 b] (5%) computador comercial

Apartado 3: Determinación de las amenazas y sus salvaguardas dispuestas.

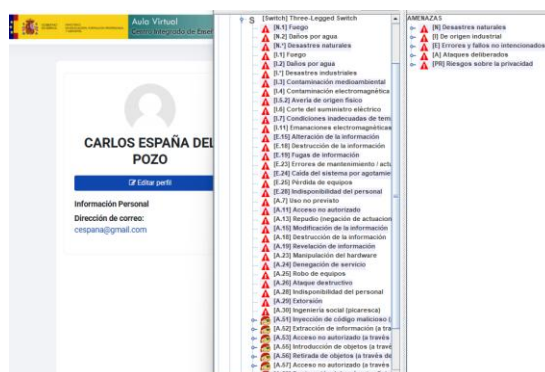
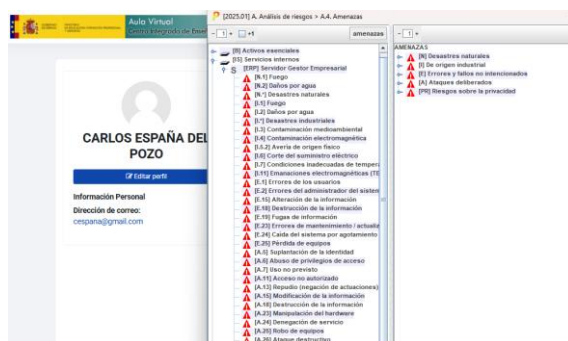
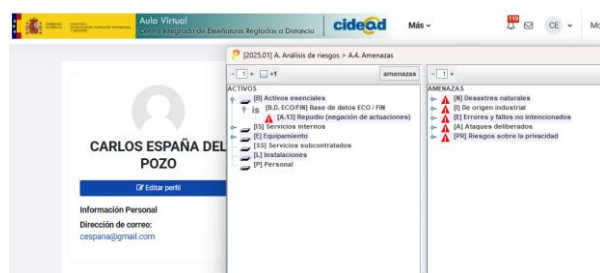
Deberás efectuar la siguiente tarea:

Para cada uno de los cuatro activos seleccionados en el apartado uno, indica la lista de amenazas asociada a estos activos. Realiza una captura de cada activo con su lista de amenazas asociada.

Además, para cada dominio de seguridad recoge las salvaguardas que te muestra la herramienta ordenada de mayor a menor prioridad según la herramienta. Para cada una de estas salvaguardas debes indicar una acción concreta que se puede realizar para llevarla a cabo en cierto grado. Incluye también el estado actual y el estado objetivo de esta salvaguarda.

Respuestas 3

A continuación, detallo la lista de amenazas asociada a estos activos.



CARLOS ESPAÑA DEL POZO

[\[?\] Editar perfil](#)

Información Personal

Dirección de correo: cespana@gmail.com

ACTIVOS

- [B] Activos esenciales
- [SI] Servicios internos
- [E] Equipamiento
- [SW] Aplicaciones
- [HW] Equipos
- [Switch] Three Legged Switch
- [S] [SOC] IDS/SIEM/NS/Vault
- [A.51] Inyección de código malicioso (a través de)
- [A.52] Extracción de información (a través de)
- [A.53] Acceso no autorizado (a través de)
- [A.55] Introducción de objetos (a través de)
- [A.56] Retirada de objetos (a través de)
- [A.57] Acceso no autorizado (a través de)
- [A.58] Destrucción del perímetro físico
- [COM] Comunicaciones
- [AUX] Elementos auxiliares
- [SS] Servicios subcontratados
- [LI] Instalaciones
- [P] Personal

AMENAZAS

- [N] Desastres naturales
- [I] De origen industrial
- [E] Errores y fallos no intencionados
- [A] Ataques deliberados
- [PR] Riesgos sobre la privacidad

esp	isp	reco	nivel	salvaguarda	act.	objet.	recom.	est.
SALVAGUARDAS								
G	EL			[PA] Identificación y autenticación	R.A.	R.A.	R.A.	R.A.
T	EL			[AC] Control de acceso lógico	R.A.	R.A.	R.A.	R.A.
G	PR			[PI] Protección de la información	R.A.	R.A.	R.A.	R.A.
G	EL			[SC-12] Protección de claves criptográficas (SC-12)	R.A.	R.A.	R.A.	R.A.
G	PR			[PS] Protección de los Servicios	R.A.	R.A.	R.A.	R.A.
G	PR			[SIW] Protección de las Aplicaciones Informáticas (SIW)	R.A.	R.A.	R.A.	R.A.
G	PR			[SIW] Protección de los Equipos Informáticos (SIW)	R.A.	R.A.	R.A.	R.A.
G	PR			[COM] Protección de las Comunicaciones	R.A.	R.A.	R.A.	R.A.
G	PR			[SI] Protección de los Sistemas de Información	R.A.	R.A.	R.A.	R.A.
G	PR			[AUX] Elementos Auxiliares	R.A.	R.A.	R.A.	R.A.
F	EL			[PRF] Protección física de los equipos	R.A.	R.A.	R.A.	R.A.
F	PR			[LI] Protección de las Instalaciones	R.A.	R.A.	R.A.	R.A.
F	PR			[PP] Gestión del Personal	R.A.	R.A.	R.A.	R.A.
G	CR			[MI] Gestión de incidentes	R.A.	R.A.	R.A.	R.A.
T	PR			[H] Herramientas de seguridad	R.A.	R.A.	R.A.	R.A.
G	CR			[V] Gestión de vulnerabilidades	R.A.	R.A.	R.A.	R.A.
T	PR			[A] Registro y auditoría	R.A.	R.A.	R.A.	R.A.
G	RC			[BC] Continuidad del negocio	R.A.	R.A.	R.A.	R.A.
G	AD			[O] Organización	R.A.	R.A.	R.A.	R.A.
G	AD			[RE] Relaciones Externas	R.A.	R.A.	R.A.	R.A.
G	AD			[R] Recuperación / desarrollo	R.A.	R.A.	R.A.	R.A.
G	PR			[P] Servicios anteriormente peligrosos	R.A.	R.A.	R.A.	R.A.
G	PR			[SI] Sistema de protección de frontera lógica	R.A.	R.A.	R.A.	R.A.
F	EL			[PPF] Protección del perímetro físico	R.A.	R.A.	R.A.	R.A.
G	EL			[TEP] Protección de empujones (TEP)	R.A.	R.A.	R.A.	R.A.

Apartado 4: Estimación del riesgo que tendría que considerar la empresa para su estudio y toma de decisiones.

Deberás efectuar la siguiente tarea:

Para cada uno de los cuatro activos seleccionados en el apartado uno, indica la estimación del estado del riesgo a asumir por la empresa. Se debe indicar la estimación actual (current) y la estimación objetivo (target).

Calcula la bajada que se produce en los riesgos en cada uno de los criterios de seguridad para cada activo.

Además, muestra una captura de la gráfica de riesgos de tipo "Área" en la que se muestran los cuatro activos con sus valores actuales, objetivo y recomendados por PILAR.

Respuestas 4

A continuación, detallo los riesgos en cada uno de los criterios de seguridad para cada activo.

INICIAL



GOBIERNO DE ESPAÑA

GOVERN OF SPAIN

Ministerio de Educación

Ministry of Education

Centro Integrado de Enseñanzas

Integrated Center of Teaching

Aula Virtual

Centro Integrado de Enseñanzas



CARLOS ESPAÑA DEL POZO

✎ Editar perfil

Información Personal

Dirección de correo:

cspesana@gmail.com

	potencial	inicial	optimo	pilar
ACTIVOS	[D]	[I]	[C]	[A]
is B.D. ECO/FIN Base de datos ECO / FIN	(6,1)	(6,1)	(8,6)	(4,9)
o [D] disponibilidad	(5,2)	(5,2)	(4,8)	(4,9)
o [I] integridad de los datos		(5,2)		
o [C] confidencialidad de los datos			(4,8)	
o [A] autenticidad de los usuarios y de la información				(4,9)
o [T] trazabilidad del servicio y de los datos				
S [ERP] Servidor Gestor Empresarial	(5,2)	(5,2)	(4,8)	(4,9)
o [D] disponibilidad	(5,2)			
o [I] integridad de los datos		(5,2)		
o [C] confidencialidad de los datos			(4,8)	
o [A] autenticidad de los usuarios y de la información				(4,9)
o [T] trazabilidad del servicio y de los datos				
[Switch] Three-Legged Switch	(6,1)	(6,1)	(8,6)	
o [D] disponibilidad	(5,1)			
o [I] integridad de los datos		(5,1)		
o [C] confidencialidad de los datos			(8,6)	
o [A] autenticidad de los usuarios y de la información				
o [T] trazabilidad del servicio y de los datos				(5,2)

OPTIMO



Autua Virtual

Centro Integrado de Enseñanzas



CARLOS ESPAÑA DEL POZO

✎ Editar perfil

Información Personal

Dirección de correo:
cespana@gmail.com

potencial

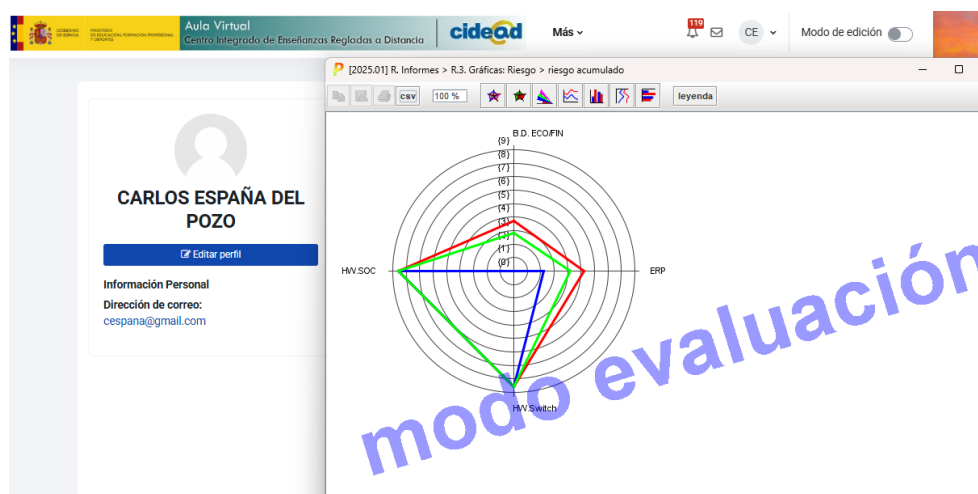
inicial

optimo

PILAR

activo

	[D]	[I]	[C]	[A]	[T]	[DP]
ACTIVOS	(6,1)	(6,1)	(8,6)	(2,1)	(1,6)	
↳ B.D. ECOFIN Base de datos ECO / FIN	(2,1)	(2,2)	(1,5)	(2,1)	(1,6)	
↳ [D] disponibilidad	(2,1)					
↳ [I] integridad de los datos		(2,2)				
↳ [C] confidencialidad de los datos			(1,5)			
↳ [A] autenticidad de los usuarios y de la información				(2,1)		
↳ [T] trazabilidad del servicio y de los datos					(1,6)	
↳ S [ERP] Servidor Gestor Empresarial	(2,1)	(2,2)	(1,5)	(2,1)	(1,6)	
↳ [D] disponibilidad	(2,1)					
↳ [I] integridad de los datos		(2,2)				
↳ [C] confidencialidad de los datos			(1,5)			
↳ [A] autenticidad de los usuarios y de la información				(2,1)		
↳ [T] trazabilidad del servicio y de los datos					(1,6)	
↳ [Switch] Three-Legged Switch	(5,1)	(5,1)	(8,6)			(0,94)
↳ [D] disponibilidad	(5,1)					
↳ [I] integridad de los datos		(5,1)				
↳ [C] confidencialidad de los datos			(8,6)			
↳ [A] autenticidad de los usuarios y de la información						
↳ [T] trazabilidad del servicio y de los datos					(0,94)	



Apartado 5: Taxonomía de incidentes.

Deberás efectuar la siguiente tarea:

Para cada uno de los cuatro activos seleccionados en el apartado uno y tras el estudio de sus riesgos, determina un tipo de incidente que podría producirse en relación a sus riesgos. Para este tipo de incidente indica el grupo al que pertenece y realiza una pequeña explicación sobre este.

Respuestas 5

Estos serían los posibles incidentes que podría producirse en relación a sus riesgos de los cuatro activos:

Switch

Fallo de hardware que provoca interrupción en el tráfico de red.

Un fallo en la electrónica del switch (fuente de alimentación, etc.) puede dejar sin conectividad a los equipos conectados. Esto provocaría un fallo de comunicaciones global y afectaría a los servicios críticos que dependen de la red, afectando al rendimiento y continuidad del negocio.

ERP

Acceso no autorizado al ERP mediante explotación de una vulnerabilidad.

Una vulnerabilidad en el software/aplicativo puede permitir que un atacante acceda al ERP, obteniendo información interna o datos sensibles del negocio. Esto compromete la confidencialidad del servicio.

B.D. ECO/FIN

Corrupción de la base de datos por fallo de almacenamiento.

Un error en la BBDD o en una transacción puede dañar los datos financieros y contables almacenados. La pérdida de integridad en esta información puede tener un impacto grave en la contabilidad, informes económicos y toma de decisiones.

SOC

Malware o manipulación del sistema que altera los logs del SIEM.

Si un atacante compromete el sistema SOC, podría modificar o eliminar registros del SIEM, impidiendo la correcta auditoría y seguimiento de incidentes.